

Production E-Commerce API - Security Architecture - Saira Saeed

Owner: Saira Saeed

Reviewer:

Contributors:

Date Generated: Wed Jul 22 2026

Executive Summary

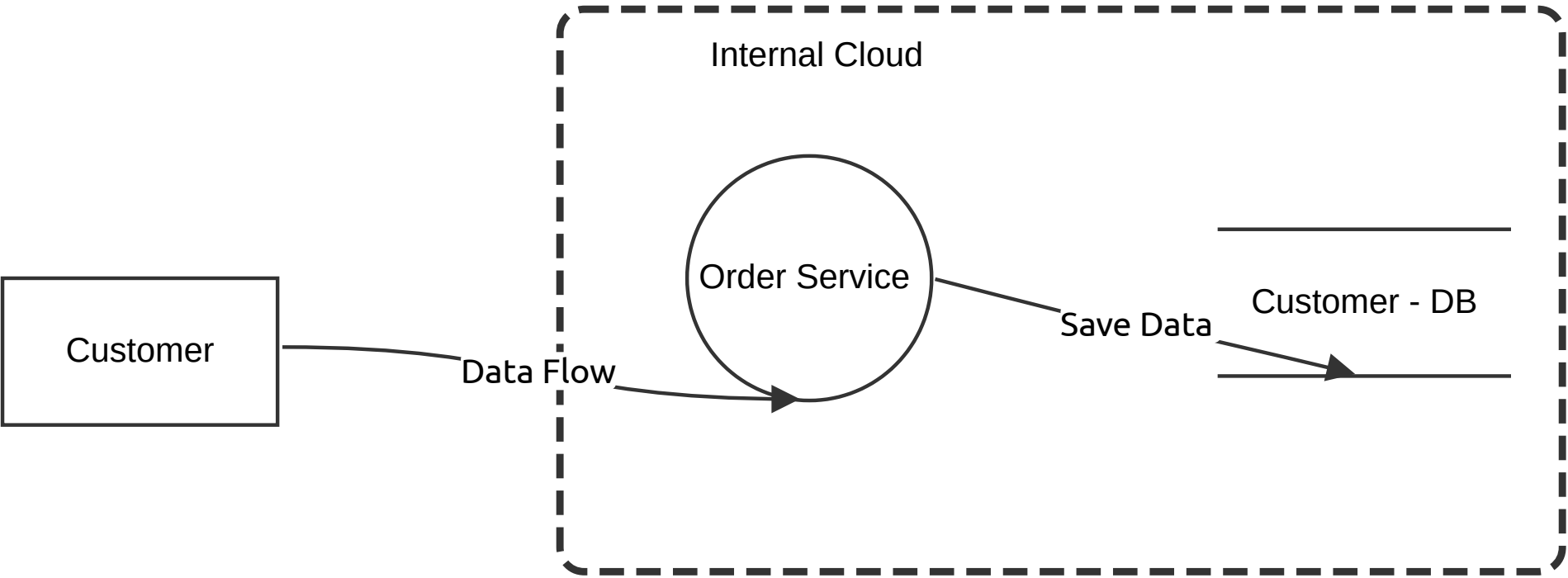
High level system description

Sensitive Data Handling via Stripe & PostgreSQL

Summary

Total Threats	9
Total Mitigated	9
Total Open	0
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0

E-Commerce Nest JS API



E-Commerce Nest JS API

Customer (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	User Account Impersonation	Spoofing	High	Mitigated		An attacker uses stolen credentials to log in as a legitimate customer.s threat	- Multi-Factor Authentication (MFA) - Strong password policy - Account lockout after repeated failed logins
6	Session Hijacking	Spoofing	High	Mitigated		Attacker steals a user's active session token.	HTTPS Secure Cookies Short-lived JWT Tokens

Order Service (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Order Tampering	Tampering	High	Mitigated		An attacker modifies order quantities or prices during processing.	Server-side validation Digital signatures Integrity checks
2	Unauthorized Order Access	Elevation of privilege	High	Mitigated		A user accesses another customer's order details.	Role-Based Access Control (RBAC) Ownership validation Authorization middleware

Customer - DB (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Sensitive Data Exposure	Information disclosure	Critical	Mitigated		Sensitive customer information is exposed due to weak encryption or access controls.	AES-256 Encryption Database access control Encryption at rest
8	Database Modification	Tampering	High	Mitigated		Unauthorized users modify customer or order records.	Least-privilege database accounts Audit logs Backups

Data Flow (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	Man-in-the-Middle (MITM)	Information disclosure	High	Mitigated		An attacker intercepts data transmitted between the customer and the API.	HTTPS TLS 1.3 Certificate Validation
10	Replay Attack	Tampering	Medium	Mitigated		An attacker captures a valid request and replays it to repeat a transaction.	Nonce Timestamp validation JWT expiration

Save Data (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Data Manipulation	Tampering	High	Mitigated		Data is altered while being transmitted between the API and the database.	Encrypted connections Integrity validation Secure database channels